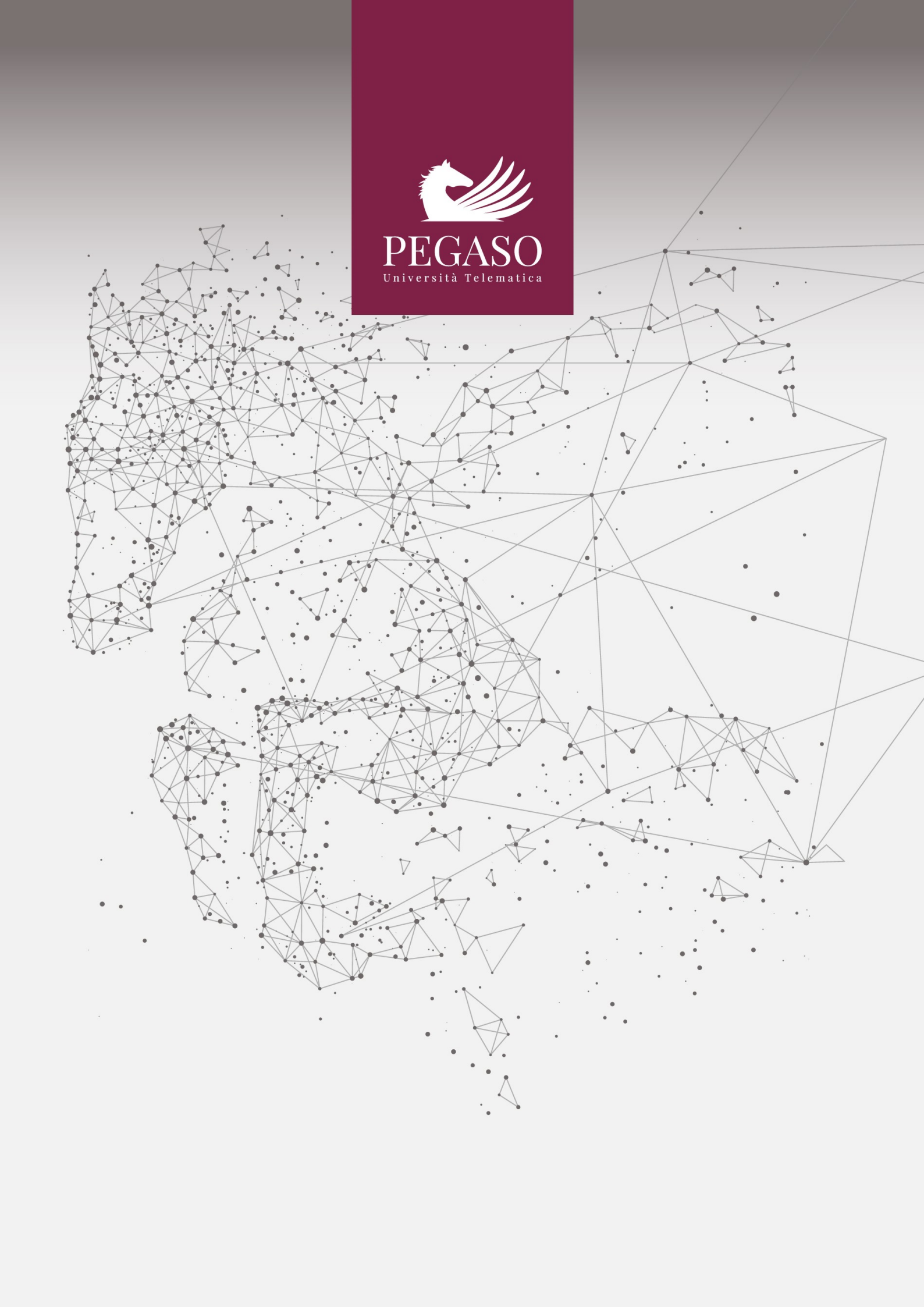

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1 SAFE HARBOR E IL CASO SCHREMS 3

2 IL PRIVACY SHIELD 8

3 IL CASO SCHREMS II E IL TRASFERIMENTO OGGI 11

BIBLIOGRAFIA 15

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1 Safe Harbor e il caso Schrems

Fin dall'inizio del secolo i trasferimenti di dati personali tra Unione Europea e Stati Uniti sono stati oggetto di particolari accordi. A seguito dell'entrata in vigore della Direttiva 95/46/CE, infatti, per trasferire dati personali al di fuori dell'allora Comunità europea erano necessarie una serie di garanzie, la cui disciplina è stata oggi trasposta integralmente nel Regolamento UE 679/2016 (GDPR). Tra il 1998 e il 2000 furono quindi sviluppati i Safe Harbor Privacy Principles, che fornivano un meccanismo per assicurare la sicurezza dei trasferimenti di dati personali tra UE e USA. Le aziende statunitensi che aderivano ai principi del Safe Harbor venivano certificate e, in questo modo, potevano dimostrare di rispettare i requisiti della Direttiva 95/46/CE.

Nel 2000, con la "Safe Harbor decision" (200/520/CE) la Commissione Europea ha stabilito che le imprese che avessero registrato la certificazione ai sensi del Safe Harbor avrebbero potuto effettuare trasferimenti internazionali di dati tra UE e USA ai sensi della disciplina europea.

I principi del Safe Harbor erano i seguenti:

"*NOTIFICA*

Le organizzazioni devono informare i singoli individui in merito alle finalità per cui vengono raccolte e utilizzate le informazioni su di essi, alle modalità per contattare le organizzazioni in relazione ad eventuali quesiti o reclami, alla tipologia dei terzi a cui vengono fornite le informazioni, e infine ad opzioni e mezzi che le organizzazioni mettono a disposizione dei singoli individui per limitare l'utilizzazione e la rivelazione delle informazioni. Queste indicazioni vanno formulate in un linguaggio chiaro e in modo da attirare l'attenzione quando si tratti del primo invito a fornire informazioni personali alle organizzazioni rivolto ad una persona oppure non appena ciò risulti successivamente possibile, ma comunque prima che le organizzazioni utilizzino o rivelino per la prima volta a terzi tali informazioni per finalità diverse da quelle per le quali le informazioni stesse erano state originariamente raccolte.

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

SCELTA

Un'organizzazione deve offrire agli individui la possibilità di scegliere (facoltà di rifiuto) se le informazioni personali che li riguardano vadano a) rivelate a terzi, ovvero b) utilizzate per fini incompatibili con quelli per cui le informazioni stesse erano state originariamente raccolte o con quelli successivamente autorizzati dall'interessato. Agli interessati andranno forniti mezzi chiari, agevolmente riconoscibili in quanto tali, di rapida fruizione e di costo accettabile per esercitare la propria scelta.

Per le informazioni di carattere delicato (ossia informazioni personali concernenti condizioni mediche o sanitarie, origine etnica o razziale, opinioni politiche, credenze filosofiche o religiose, appartenenza a sindacati, o la vita sessuale dell'individuo), va data la possibilità di scelta affermativa o esplicita (facoltà di consenso) per quanto riguarda la possibilità che le informazioni in questione vengano rivelate a terzi od utilizzate per scopi diversi da quelli per cui esse erano state originariamente raccolte o da quelli successivamente autorizzati dagli interessati con l'esercizio della facoltà di consenso. Un'organizzazione è in ogni caso tenuta a considerare di carattere delicato qualsiasi informazione ricevuta da un terzo che la definisca e la consideri tale.

TRASFERIMENTO SUCCESSIVO

Le organizzazioni che comunicano informazioni a terzi devono applicare i principi di notifica e di scelta. Un'organizzazione che intende trasferire informazioni a terzi che agiscono in qualità di rappresentanti, come specificato nella nota, lo può fare a condizione di accertarsi prima che questi ultimi aderiscono ai principi dell'approdo sicuro, o rientrano nel campo d'applicazione della direttiva o di un'altra forma d'accertamento dell'idoneità, ovvero di stipulare con i terzi un accordo scritto che comporti per essi l'obbligo di offrire almeno lo stesso livello di protezione della riservatezza richiesto dai relativi principi. Un'organizzazione che ottemperi a tali prescrizioni non può essere ritenuta responsabile (salvo che non abbia concordato altrimenti) se i terzi, cui ha trasferito l'informazione, la elaborano secondo modalità contrarie a quanto imposto o dichiarato, a meno che l'organizzazione stessa non fosse od avesse dovuto essere a conoscenza del fatto che i terzi in

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

questione avrebbero proceduto in tal modo e non abbia preso provvedimenti ragionevoli per impedire che ciò accadesse o porvi termine.

SICUREZZA

Le organizzazioni che detengono, aggiornano, utilizzano o diffondono informazioni personali devono prendere ragionevoli precauzioni per proteggerle da perdita ed abusi nonché da accesso, rivelazione, alterazione e distruzione non autorizzati.

INTEGRITÀ DEI DATI

Conformemente a questi principi le informazioni personali devono risultare pertinenti ai fini per cui sono state raccolte od a quelli successivamente autorizzati dagli interessati. Se ed in quanto necessario per tali fini un'organizzazione deve prendere provvedimenti ragionevoli per garantire che i dati siano attendibili in funzione dell'uso che si prevede di farne, accurati, completi e aggiornati.

ACCESSO

Gli individui devono poter accedere alle informazioni personali che li riguardano in possesso di una data organizzazione, ed altresì poterle correggere, emendare o cancellare se ed in quanto esse risultino inesatte, salvo il caso specifico in cui l'onere o la spesa che tale accesso comporta siano sproporzionati ai rischi per la riservatezza degli interessati oppure vengano violati i diritti di persone che non siano i diretti interessati.

GARANZIE D'APPLICAZIONE

Per tutelare efficacemente la riservatezza dei dati personali occorre disporre meccanismi volti a garantire il rispetto dei principi, la possibilità di ricorso per gli individui cui si riferiscono i dati che vedano lesi i propri interessi dal mancato rispetto dei principi stessi, e la non impunità di un'organizzazione che non rispetti i principi. Nel novero di detti meccanismi devono rientrare come minimo: a) meccanismi di ricorso indipendenti, di pronto impiego e di costo accessibile, atti a consentire d'istruire e dirimere qualsiasi ricorso o contenzioso individuale grazie all'applicazione dei

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

principi nonché di riconoscere gli indennizzi del caso laddove questa possibilità sia contemplata dalla legge o da iniziative del settore privato; b) procedure di controllo per verificare la veridicità di attestati e affermazioni rilasciati dalle organizzazioni riguardo alle proprie pratiche in fatto di riservatezza dei dati personali e l'effettivo rispetto degli impegni presi a questo

proposito; e c) l'obbligo di rimediare ad eventuali problemi insorti in seguito al mancato rispetto dei principi da parte di organizzazioni che dichiarino di aderirvi, con precisazione delle conseguenze che ciò comporta per tali organizzazioni. Le sanzioni devono risultare sufficientemente rigorose da garantire il rispetto dei principi da parte delle organizzazioni."

Nel 2013, a seguito delle rivelazioni di Edward Snowden sulla sorveglianza dei cittadini da parte dei servizi di intelligence statunitensi, Maximillian Schrems, un attivista austriaco, ha segnalato al Data Protection Commissioner (DPC) irlandese le attività di trasferimento di dati dei cittadini europei che Facebook Ireland Ltd effettuava nei confronti della corrispondente compagnia stabilita negli USA Facebook Inc., sostenendo che la privacy dei cittadini europei fosse minata da tali operazioni e chiedendone la cessazione.

A seguito della risposta negativa da parte del DPC, Schrems ha portato il caso di fronte alla High Court irlandese, che ha deferito la questione alla Corte di Giustizia dell'Unione Europea (CGUE), la quale il 6 ottobre 2015 ha emanato la celebre sentenza C-362/14 *Maximillian Schrems/Data Protection Commissioner* (conosciuta come "Schrems I").

Con la sentenza "Schrems I", la CGUE ha dichiarato invalida la decisione 2000/520/CE della Commissione e, quindi, il meccanismo del Safe Harbor è divenuto inapplicabile per consentire i trasferimenti di dati personali tra UE e USA.

Le criticità individuate dalla CGUE sono di fatto riassumibili nel modo seguente:

1. La sorveglianza attuata negli Stati Uniti era in contrasto con la normativa europea a tutela della privacy dei soggetti;
2. Il meccanismo del Safe Harbor non forniva rimedi legali adeguati nel caso di violazioni.

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

A questo punto, Facebook Ireland Ltd non poteva più trasferire dati dei cittadini europei sulla base del Safe Harbor. Ha tuttavia proseguito con i trasferimenti, utilizzando clausole contrattuali standard ai sensi della Decisione 2010/87 della Commissione Europea. Tuttavia, i problemi di sorveglianza da parte dell'intelligence statunitense permanevano anche utilizzando questo diverso meccanismo; per tale motivo, Maximillian Schrems ha sottoposto all'Autorità garante privacy irlandese una questione sulla validità della Decisione 2010/87 e ancora una volta il problema è stato portato all'attenzione della CGUE.

Nel frattempo, è intervenuta la Decisione 2016/1250 della Commissione Europea a sancire l'adeguatezza del nuovo sistema di trasferimento dei dati personali tra UE e USA: il Privacy Shield.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2 Il Privacy Shield

Il Privacy Shield era il nuovo accordo siglato tra la Commissione Europea e il Dipartimento del Commercio degli Stati Uniti per consentire il trasferimento di dati personali tra UE e USA.

Era stato approvato dalla Commissione Europea con la Decisione 2016/1250 ed era in linea con quanto richiesto dalla CGUE nella sentenza del caso Schrems I: era previsto un controllo maggiore da parte delle autorità statunitensi sul rispetto dell'accordo, una collaborazione tra tali autorità e i Garanti privacy europei e delle dichiarazioni e impegni formali per quanto riguardava l'accesso ai dati da parte delle pubbliche amministrazioni statunitensi.

Gli elementi fondamentali dell'accordo sono stati così schematizzati dal Garante per la protezione dei dati personali:

"*SETTORE COMMERCIALE*

Obblighi stringenti per le imprese e rigide misure di attuazione

- Più trasparenza

- Meccanismi di controllo del rispetto delle regole da parte delle imprese

- Sanzioni o esclusione dai benefici dell'accordo per le imprese che non lo rispettano

- Condizioni più rigide per trasferire i dati a destinatari ulteriori.

ACCESSO AI DATI DA PARTE DELL'AMMINISTRAZIONE USA

Precise garanzie e obblighi di trasparenza

- Per la prima volta, l'Amministrazione USA ha garantito formalmente che l'accesso delle autorità pubbliche ai dati personali sarà soggetto a limiti, garanzie e meccanismi di controllo specifici e definiti

- Le Autorità USA affermano che non vi saranno attività di sorveglianza indiscriminata o massiva

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- Le imprese potranno dichiarare il numero approssimativo di richieste di accesso ricevute - Disponibile un nuovo strumento di tutela giuridica attraverso il cosiddetto «difensore civico» (Ombudsperson) creato per il Privacy Shield: un soggetto indipendente incaricato di ricevere e decidere i reclami presentati dagli interessati.

STRUMENTI DI TUTELA GIURIDICA

Vi sono diverse possibilità per far valere i propri diritti

*- **Rivolgersi direttamente all'impresa**, che deve rispondere, in caso di reclamo da parte di un interessato, entro 45 giorni*

*- **Utilizzare un meccanismo di ADR** (Risoluzione alternativa delle controversie), gratuito*

*- **Rivolgersi all'Autorità di protezione dati**, che collaborerà con il Department of Commerce e la Federal Trade Commission degli USA per garantire accertamenti sui reclami ancora pendenti presentati da cittadini Ue e giungere rapidamente alla loro definizione*

*- **Rivolgersi al Privacy Shield Panel** (Collegio arbitrale del Privacy Shield) per ottenere, se nessun'altra soluzione si è rivelata praticabile, una decisione esecutiva attraverso un meccanismo di arbitrato.*

MONITORAGGIO

Revisione annuale congiunta del funzionamento dell'Accordo

- Monitoraggio del funzionamento del Privacy Shield e del rispetto degli impegni assunti dagli USA anche con riguardo all'accesso ai dati per finalità di polizia e giustizia o di sicurezza nazionale

- La revisione sarà condotta dalla Commissione europea e dal Department of Commerce USA con il coinvolgimento di esperti dei servizi di sicurezza americani e delle Autorità europee per la protezione dei dati

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- Previsto un vertice annuale, con la partecipazione di ONG e altri soggetti interessati, dedicato agli sviluppi nel settore della normativa privacy negli USA e al relativo impatto sugli europei

- La Commissione europea presenterà una relazione pubblica al Parlamento e al Consiglio, basandosi sui risultati della revisione annuale congiunta e su altre informazioni pertinenti (ad esempio, le relazioni sulla trasparenza presentate dalle imprese).

IN PRATICA

Le imprese americane

- Autocertificheranno su base annuale il rispetto degli obblighi

- Dovranno pubblicare una privacy policy (informativa privacy) sul loro sito

- Dovranno rispondere tempestivamente ai reclami

- Dovranno collaborare con le Autorità europee per la protezione dei dati e dare seguito alle loro richieste (se trattano dati relativi al personale/alle risorse umane)

Gli interessati in Europa

- Godranno di più trasparenza rispetto ai trasferimenti di dati personali negli USA e di una tutela rafforzata per questi dati

- Avranno a disposizione strumenti di tutela giuridica più facili da utilizzare e meno costosi in caso di reclami, che potranno gestire da soli oppure con l'aiuto dell'Autorità nazionale di protezione dei dati.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3 Il caso Schrems II e il trasferimento oggi

La questione dei trasferimenti di dati tra UE e USA è approdata nuovamente di fronte alla CGUE con le seguenti domande poste dalla High Court irlandese:

1. se il GDPR sia applicabile ai trasferimenti di dati personali che avvengono sulla base di clausole contrattuali standard;
2. quale livello di protezione sia richiesto dal GDPR in relazione a tali trasferimenti;
3. quali siano i compiti delle Autorità garanti in queste circostanze;
4. validità della Decisione 2010/87 (clausole contrattuali standard) e della Decisione 2016/1250 (Privacy Shield).

Il 16 luglio 2020 la CGUE ha quindi emanato la sentenza relativa al caso c.d. "Schrems II", stabilendo che:

"*1) L'articolo 2, paragrafi 1 e 2, del regolamento (UE) 2016/679 del Parlamento europeo e del Consiglio, del 27 aprile 2016, relativo alla protezione delle persone fisiche con riguardo al trattamento dei dati personali, nonché alla libera circolazione di tali dati e che abroga la direttiva 95/46/CE (regolamento generale sulla protezione dei dati), deve essere interpretato nel senso che rientra nell'ambito di applicazione di tale regolamento un trasferimento di dati personali effettuato a fini commerciali da un operatore economico stabilito in uno Stato membro verso un altro operatore economico stabilito in un paese terzo, nonostante il fatto che, durante o in seguito a tale trasferimento, i suddetti dati possano essere sottoposti a trattamento da parte delle autorità del paese terzo considerato a fini di sicurezza pubblica, di difesa e sicurezza dello Stato.*

2) L'articolo 46, paragrafo 1, e l'articolo 46, paragrafo 2, lettera c), del regolamento 2016/679 devono essere interpretati nel senso che le garanzie adeguate, i diritti azionabili e i mezzi di ricorso effettivi richiesti da tali disposizioni devono garantire che i diritti delle persone i cui dati personali

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

sono trasferiti verso un paese terzo sul fondamento di clausole tipo di protezione dei dati godano di un livello di protezione sostanzialmente equivalente a quello garantito all'interno dell'Unione da tale regolamento, letto alla luce della Carta dei diritti fondamentali dell'Unione europea. A tal fine, la valutazione del livello di protezione garantito nel contesto di un trasferimento siffatto deve, in particolare, prendere in considerazione tanto le clausole contrattuali convenute tra il titolare del trattamento o il responsabile del trattamento stabiliti nell'Unione e il destinatario del trasferimento stabilito nel paese terzo interessato quanto, per quel che riguarda un eventuale accesso delle autorità pubbliche di tale paese terzo ai dati personali così trasferiti, gli elementi rilevanti del sistema giuridico di quest'ultimo, in particolare quelli enunciati all'articolo 45, paragrafo 2, di detto regolamento.

3) L'articolo 58, paragrafo 2, lettere f) e j), del regolamento 2016/679 deve essere interpretato nel senso che, a meno che esista una decisione di adeguatezza validamente adottata dalla Commissione europea, l'autorità di controllo competente è tenuta a sospendere o a vietare un trasferimento di dati verso un paese terzo effettuato sulla base di clausole tipo di protezione dei dati adottate dalla Commissione, qualora detta autorità di controllo ritenga, alla luce del complesso delle circostanze proprie di tale trasferimento, che le suddette clausole non siano o non possano essere rispettate in tale paese terzo e che la protezione dei dati trasferiti richiesta dal diritto dell'Unione, segnatamente dagli articoli 45 e 46 di tale regolamento e dalla Carta dei diritti fondamentali, non possa essere garantita con altri mezzi, ove il titolare del trattamento o il responsabile del trattamento stabiliti nell'Unione non abbiano essi stessi sospeso il trasferimento o messo fine a quest'ultimo.

4) Dall'esame della decisione 2010/87/UE della Commissione, del 5 febbraio 2010, relativa alle clausole contrattuali tipo per il trasferimento di dati personali a incaricati del trattamento stabiliti in paesi terzi a norma della direttiva 95/46/CE del Parlamento europeo e del Consiglio, come modificata dalla decisione di esecuzione (UE) 2016/2297 della Commissione, del 16 dicembre 2016, alla luce degli articoli 7, 8 e 47 della Carta dei diritti fondamentali non è emerso alcun elemento idoneo ad inficiarne la validità.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

5) La decisione di esecuzione (UE) 2016/1250 della Commissione, del 12 luglio 2016, a norma della direttiva 95/46/CE del Parlamento europeo e del Consiglio, sull'adeguatezza della protezione offerta dal regime dello scudo UE-USA per la privacy, è invalida."

Dunque, riassumendo:

1. Il GDPR si applica ai trasferimenti di dati tra operatori economici stabiliti uno nell'Unione e uno in un Paese terzo anche se questi dati, nel momento del trasferimento o in seguito, potrebbero essere trattati dalle autorità del Paese terzo per fini di difesa o pubblica sicurezza.

2. Il livello di protezione che deve essere assicurato è quello garantito nell'Unione. Deve essere valutato tenendo in considerazione le clausole contrattuali presenti in accordi tra l'esportatore e l'importatore di dati e gli aspetti rilevanti del sistema legale del Paese terzo.

3. Se le Autorità garanti privacy si rendono conto che, viste le circostanze del trasferimento, le clausole contrattuali standard non possono essere rispettate e la protezione dei dati dei cittadini europei non può essere assicurata in altro modo, devono sospendere o proibire il trasferimento dei dati verso quel Paese.

4. La Decisione 2010/87 resta valida.

5. La Decisione 2016/1250 viene annullata perché i programmi di sorveglianza negli USA non sono limitati allo stretto necessario e, dunque, non rispettano il principio di proporzionalità e perché il meccanismo di ricorso al Difensore Civico non fornisce agli interessati alcuna possibilità di agire di fronte a un organo che offra le stesse garanzie presenti nella legislazione europea.

A seguito della sentenza della CGUE, tutti i titolari del trattamento che trasferiscono dati personali negli USA devono controllare di poter ancora effettuare tale attività e, se necessario, utilizzare una diversa garanzia tra quelle previste dagli articoli 46 e seguenti del

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

GDPR. Sul sito del Garante per la protezione dei dati personali è reperibile la traduzione italiana delle FAQ dell'European Data Protection Board "Domande frequenti sulla sentenza della Corte di giustizia dell'Unione europea nella causa C-311/18 — Data Protection Commissioner/Facebook Ireland Ltd e Maximillian Schrems" adottate il 23 luglio 2020 per guidare i titolari nella valutazione delle implicazioni della caduta del Privacy Shield sulla loro attività.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Gabriele Faggioli, Anna Cataleta, Sentenza Schrems è una vittoria per la sovranità digitale degli europei: ecco perché, AgendaDigitale 21 luglio 2020
- Garante per la protezione dei dati personali, Privacy shield. Lo Scudo per la privacy fra Ue e USA – Infografica (doc. web 5295490)

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).